

The Gatekeeper's Upgrade: IAM Refactoring & Defense Instructional Requirements 02

By Bryan Kim Calipes

Project Identity & Retrospective

PAULICODE: A Web-based Application that teaches Programming & Cybersecurity in an interactive way between Teacher & Student

Original Design Goals

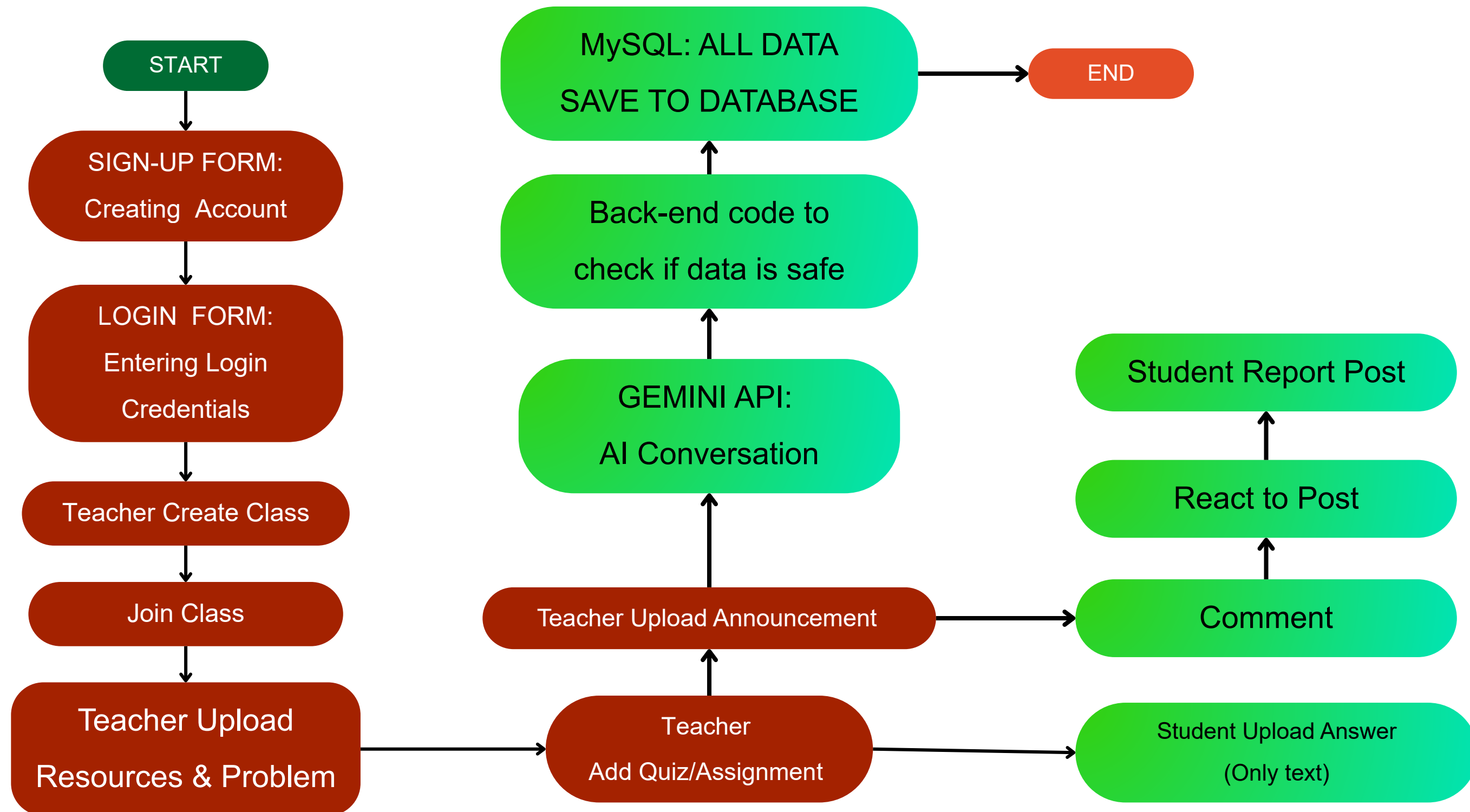
This application teaches students programming and cybersecurity in a fun and interactive way. It promotes academic integrity by implementing anti-cheating security measures, such as preventing the copy-pasting of AI-generated code for submission to teachers.

At the same time, the system introduces cybersecurity concepts through hands-on learning. Students explore topics posted by their teachers, like encryption, steganography, and other security techniques using Capture-the-Flag (CTF)-style gamification, making learning both engaging and practical.

The Legacy Tech Stack

1. Django
2. Python
3. MySQL
4. HTML
5. CSS
6. BOOTSTRAP

The Trust Boundary



The Unpolished State (The Vulnerable "Before")

```
1 <div>
2   <main class="main-content">
3     <section class="w-100">
4       <div class="page-header">
5         <div class="container ms-5">
6           <div class="row justify-content-center">
7             <div class="col-xl-4 col-lg-5 col-md-6 col-sm-8 col-12">
8               <!-- Main Sign In Card -->
9               <div class="card" style="background-color: #2d2d2d; border: 1px solid #404040; border-radius:
10                20px;">
11                 <div class="card-body px-4 py-4">
12                   <!-- Logo -->
13                   <div class="text-center mb-3">
14                     
16                   </div>
17                   <!-- Welcome Text -->
18                   <div class="text-center mb-3">
19                     <h4 class="text-white font-weight-bolder mb-2">Welcome Back!</h4>
20                     <p class="text-muted mb-0 small">Sign in to continue your learning journey</p>
21                   </div>
22                   <!-- Form -->
23                   <form role="form" method="POST" action="{% url 'login' %}">
24                     {% csrf_token %}
25
26                     <div class="mb-3">
27                       <label class="text-white mb-2 small font-weight-bold">School ID</label>
28                       <input type="text"
29                         name="school_id"
30                         class="form-control"
31                         placeholder="Enter your School ID"
32                         required
33                         style="background-color: #1a1a1a; border: 1px solid #404040; border-radius: 10px;
34                         color: white;">
35                     </div>
36
37                     <div class="mb-3">
38                       <label class="text-white mb-2 small font-weight-bold">Password</label>
39                       <input type="password"
40                         name="password"
41                         class="form-control"
```

```

44         </div>
45
46         <div class="form-check mb-3">
47             <input class="form-check-input" type="checkbox" id="rememberMe">
48             <label class="form-check-label text-white small" for="rememberMe">Remember me</label>
49         </div>
50
51
52
53
54
55         <div class="text-center">
56             <button type="submit"
57                 class="btn w-100 mb-3 font-weight-bold"
58                 style="background-color: #4CD964; border-radius: 10px; border: none; color:
black;">
59                 Log In
60             </button>
61         </div>
62
63         <div class="text-center">
64             <a href="#" class="text-decoration-none small" style="color: #4CD964;">Forgot Password?
65         </a>
66         </div>
67     </form>
68 </div>
69 </div>
70
71 <!-- Sign Up Card -->
72 <div class="card mt-3" style="background-color: #2d2d2d; border: 1px solid #404040; border-
radius: 20px;">
73     <div class="card-body px-4 py-3 text-center">
74         <p class="text-muted mb-2 small">Don't have an account?</p>
75         <a type="button" class="btn w-100 font-weight-bold" href='{% url 'signup' %}'
style="background-color: transparent; border: 2px solid #4CD964; border-radius: 10px; color: #4CD964;">Sign
Up</a>
76     </div>
77 </div>
78 </div>
79 </div>
80 </div>
81 </div>
82 </section>
83 </main>

```

No Multifactor-Authentication & no Rate-limiting for sign-up & login

The "Security Hole"

✓ Showing rows 0 - 1 (2 total, Query took 0.0028 seconds.)

`SELECT * FROM `chat_history``

☐ Profiling [Edit inline] [Edit] [Explain SQL] [Create PHP code] [Refresh]

☐ Show all | Number of rows: 25 | Filter rows: Search this table | Sort by key: None

Extra options

				chat_id	sender	message	timestamp	school_id_id
☐	Edit	Copy	Delete	11	user	Hi	2025-12-24 14:28:50.525026	0
☐	Edit	Copy	Delete	12	ai	Hello! I'm Paulibot, your AI coding assistant from...	2025-12-24 14:28:51.683099	0

☐ Check all

With selected:

Edit

Copy

Delete

Export

☐ Show all | Number of rows: 25 | Filter rows: Search this table | Sort by key: None

Query results operations

Print

Copy to clipboard

Export

Display chart

Create view

Messages between user and ai is not encrypted in the DB

The Unpolished State (The Vulnerable "Before") - Exploit Scenario

Attackers may perform brute-force and Distributed Denial-of-Service (DDoS) attacks because the login page currently does not implement rate limiting. If attackers successfully obtain a user's credentials, they can directly access the user's account since the authentication system does not yet support two-factor authentication (2FA).

Furthermore, if an attacker gains access to administrator credentials, they could manipulate database records and view conversations between users and the AI in plain text, as these messages are not yet encrypted.

The Unpolished State (The Vulnerable "Before") - Exploit Scenario

Attackers may perform brute-force and Distributed Denial-of-Service (DDoS) attacks because the login page currently does not implement rate limiting. If attackers successfully obtain a user's credentials, they can directly access the user's account since the authentication system does not yet support two-factor authentication (2FA).

Furthermore, if an attacker gains access to administrator credentials, they could manipulate database records and view conversations between users and the AI in plain text, as these messages are not yet encrypted.

The Polished State (The Secure "After")



Welcome Back!

Sign in to continue your learning journey

A verification code has been sent to
bryancalipez28@gmail.com

Verification Code

750522

Verify & Login

[Didn't receive code? Resend](#)

[← Back to Login](#)

Don't have an account?

Sign Up

Login Verification

Hi King Kharl,

Someone is trying to log in to your PauliCode account. To complete the login process, please use the verification code below:

750522

This code will expire in 15 minutes.

If you didn't try to log in, please ignore this email and consider changing your password.

PauliCode - Interactive Coding Platform
© 2025 All rights reserved.

Now supports Two-factor Authentication when logging in

The Polished State (The Secure "After")

First Name	Last Name
Karl	Satsar
Email Address	School
nameless200320@gmail.com	Others
School ID	User Type
C-0001-0001	Student
Password	Confirm Password
karl1234	

A verification code has been sent to your email. Please enter it below to complete your registration.

Verification Code

Verify & Complete

Already have an account? [Sign in](#)

Welcome to PauliCode

Hi Bryan Kim,

Thank you for signing up! To complete your registration, please use the verification code below:

105929

This code will expire in 15 minutes.

If you didn't request this code, please ignore this email.

PauliCode - Interactive Coding Platform
© 2025 All rights reserved.

Now supports Two-factor Authentication when logging in